

INTERN DOCUMENT — niet publiceren. Bewaren zolang de verwerking plaatsvindt.

AVG art. 35 — versie 1.1 — 4 juli 2026

Verwerkingsverantwoordelijke: Dennis van Westbroek · KVK 74667653 · info@perfectsupplement.nl

DPIA — PerfectSupplement Leefstijlcheck

Versie 1.1 — vastgesteld 4 juli 2026. Vervangt PDF-snapshot v1.0 (12 april 2026).

0. Waarom deze DPIA verplicht is

De verwerking voldoet aan meerdere criteria die een DPIA verplicht maken (AVG art. 35 lid 3 + AP-lijst):

- **Bijzondere persoonsgegevens** (gezondheidsgegevens, AVG art. 9) worden op grote schaal verwerkt.
- **Systematische, geautomatiseerde beoordeling** (scoring-engine → domeinscores, profiellabel, urgentieniveau).
- **Profilering** als basis voor gepersonaliseerde content en e-mail.

Conclusie: DPIA is verplicht en hierbij uitgevoerd.

1. Systematische beschrijving van de verwerking

1.1 Doel

Gebruikers leefstijl-inzicht geven op zes domeinen (slaap, energie, stress, voeding, beweging, herstel) en daarop afgestemde, niet-medische leefstijl- en supplementinformatie aanbieden. **Uitdrukkelijk geen** diagnose, monitoring of behandeling (zie COMPLIANCE.md, beoogd doel = algemeen welzijn/leefstijl-educatie).

1.2 Categorieën betrokkenen

Volwassen websitebezoekers (doelgroep mannen ±40+) die vrijwillig de Leefstijlcheck invullen. Geen verzameling onder 16 jaar (privacyverklaring \$kinderen).

1.3 Categorieën persoonsgegevens

Categorie	Voorbeeld	Bijzonder (art. 9)?
Intake-antwoorden	answers (jsonb), symptom_profile	Ja — gezondheidsgegevens
Afgeleide scores	domain_scores, urgency_level, profile_label	Ja — afgeleide gezondheidsgegevens
Leeftijdsindicatie	age_range	Nee

Categorie	Voorbeeld	Bijzonder (art. 9)?
Contact/marketing	marketing_email, reminder-e-mail	Nee (wel gekoppeld aan art. 9)
Voeding/check-in/gewicht	periodieke rapportage, eiwitrichtlijn	Ja
Accountkoppeling	psf_account (HMAC bearer-token)	Nee (identificator)
Gedrag	affiliate_clicks, webanalyse	Nee

1.4 Ontvangers / verwerkers (bron: privacyverklaring + verwerkingsregister)

Verwerker	Rol	Locatie / waarborg
Supabase	Database	EU (Frankfurt) — DPA geaccepteerd
Hetzner	VPS-hosting	EU — DPA geaccepteerd
Cloudflare	CDN, Turnstile	Wereldwijd — Customer DPA v6.4
Resend	E-mail	VS — DPF, DPA geaccepteerd
Google Analytics 4	Webanalyse	VS — DPF; DPA geaccepteerd 23-11-2022
Microsoft Clarity	Heatmaps/recordings	VS — DPF; Microsoft Product and Services DPA
Zoho CRM	Contactformulier	EU — DPA nog in archief controleren

Volledige lijst en archiefpaden: VERWERKINGSREGISTER.md §Verwerkersovereenkomsten.

1.5 Bewaartermijnen (technisch afgedwongen, geautomatiseerd)

Gegeven	Termijn
Intake-sessies (incl. art. 9)	24 maanden, automatisch verwijderd
Reminders	12 maanden na verzending
Nurture/marketing	5 jaar na intrekking
Feedback	1 jaar
Affiliate clicks	90 dagen
Webanalyse (GA4)	14 maanden
Consent-records	5 jaar na intrekking

Bij intrekking van toestemming worden gezondheidsgegevens **geanonimiseerd of verwijderd** (consent-tekst + privacyverklaring + revoke_intake_session_consent).

1.6 Internationale doorgifte

Doorgifte buiten de EER alleen met DPF of door de EC goedgekeurde SCC's (privacyverklaring §doorgifte). Van toepassing op Resend, Google Analytics en Microsoft Clarity.

2. Rechtsgrond, noodzaak en evenredigheid

- **Rechtsgrond:** AVG art. 9 lid 2 sub a (**uitdrukkelijke toestemming**) voor bijzondere gegevens, in combinatie met art. 6 lid 1 sub a. Bevestigd in privacyverklaring en consent-texts.ts.
- **Toestemming is granulair en specifiek per doel** — aparte toestemmingen voor: supplementadvies, anonieme productanalyse, nurture-e-mail, voedingsrapportage, domein-check-in, gewicht/eiwitrichtlijn, bewaren onder e-mailadres, hermeting-reminder, contactformulier. Elke tekst bevat *"geen medisch advies en geen diagnose; ik kan dit altijd intrekken"*.
- **Vrij & intrekbaar:** toestemming wordt aan het einde van de check gevraagd; checkboxen starten op **uit** (IntakeConsent.tsx: useState(false)). Intrekbaar via website en e-mail.
- **Dataminimalisatie:** alleen leefstijl-relevante antwoorden; geen NAW behalve e-mail bij expliciete opt-in; age_range i.p.v. exacte geboortedatum.
- **Evenredigheid:** verwerking staat in verhouding tot het doel (leefstijl-inzicht); geen minder ingrijpend alternatief levert hetzelfde inzicht.

3. Risicobeoordeling voor betrokkenen

#	Risico	Kans	Impact	Maatregel
R1	Ongeoorloofde toegang tot gezondheidsgegevens	Laag	Hoog	RLS aan, HTTPS, encryptie-at-rest, HMAC bearer-token met issued-at+expiry
R2	Datalek bij verwerker	Laag	Hoog	EU-hosting (Supabase Frankfurt), DPF/SCC, verwerkersovereenkomsten gearriveerd
R3	Onnodig lange bewaring	Laag	Middel	Geautomatiseerde, technisch afgedwongen retentie + anonimisering bij intrekking
R4	Functie-creep: scores/labels gelezen als medische beoordeling	Middel	Hoog	Disclaimers (intake/dashboard/artikel), urgency_level niet user-facing, compliance-tests tegen diagnose-taal (*-assessment.test.ts, nurture-copy guard), beoogd-doel vastgelegd in COMPLIANCE.md
R5	Toestemming niet vrij/specifiek/geïnformeerd	Laag	Hoog	Granulaire opt-in per doel, geen pre-check, intrekbaar, art. 9-melding in UI
R6	Re-identificatie van "geanonimiseerde" data	Laag	Middel	Revoke-flow anonimiseert sessie-antwoorden; consent-records behouden alleen hash + tekst
R7	Profilering benadeelt betrokkene	Laag	Middel	Geen geautomatiseerde besluiten met rechtsgevolg (art. 22); output is informatief/vrijblijvend

4. Maatregelen (samenvatting)

Technisch: RLS, HTTPS, encryptie, HMAC-token (issued-at/expiry), geautomatiseerde retentie, anonimiseren bij intrekking, compliance-testsuite tegen diagnose-/ziektetaal in gepersonaliseerde output, analytics consent-gate vóór script-load, Clarity geblokkeerd op intake/dashboard-routes.

Organisatorisch: granulaire toestemming per doel, privacyverklaring + medische disclaimer, EFSA-claimregister voor supplementcommunicatie, vastgelegd niet-medisch beoogd doel, verwerkersovereenkomsten via productacceptatie (archief in Documenten/.../privacy/).

4.1 Procedure datalek melding (art. 33/34)

Stap	Actie
1. Detectie	Security logs, Supabase-alerts, melding verwerker of gebruiker → info@perfectsupplement.nl
2. Beoordeling	Binnen 24 uur: omvang, categorie gegevens, risico voor betrokkenen
3. AP-melding	Binnen 72 uur bij waarschijnlijk risico voor rechten/vrijheden → autoriteitpersoonsgegevens.nl
4. Betrokkenen	Informeren bij hoog risico (art. 34), via e-mail
5. Documentatie	Incident vastleggen: datum, oorzaak, maatregelen, meldingen — bewaren 5 jaar

5. Restrisico & conclusie

Met bovenstaande maatregelen is het restrisico **laag**. Het hoogste resterende aandachtspunt is **R4 (functie-creep richting medische interpretatie)** — beheerst via compliance-tests en disclaimers. Voorafgaande raadpleging van de AP (art. 36) is **niet** nodig.

Open administratief punt: Zoho CRM DPA nog toevoegen aan archief (verwerkingsregister).

Volgende herziening gepland: juli 2027 (jaarlijks) of eerder bij wezenlijke wijziging in verwerking.

6. Checklist vaststelling

- ☒ Verwerkingsverantwoordelijke: Dennis van Westbroek, KVK 74667653, info@perfectsupplement.nl
- ☒ FG: niet aangesteld — niet verplicht bij huidige schaal en risicoprofiel (eenmanszaak, beperkte verwerking)
- ☒ Verwerkersovereenkomsten (art. 28): Supabase, Hetzner, Cloudflare, Resend, Google Analytics, Microsoft Clarity — geaccepteerd en gearchiveerd (Zoho: controleren)
- ☒ Toestemmingsvakjes standaard uit (geen pre-check) — bevestigd in code
- ☒ Procedure datalek melding (art. 33/34) — §4.1
- ☒ Periodieke herziening: jaarlijks (volgende: juli 2027)

7. Vaststelling

Rol	Naam	Datum	Akkoord
Verwerkingsverantwoordelijke	Dennis van Westbroek	2026-07-04	Vastgesteld
FG / adviseur	n.v.t.	—	—